BUILD DIRECTIVE · v1.0

에셋온(AssetOn) 자산관리시스템 제작지시서

GitHub · Cloudflare 중심의 기술 스택, 저장소·CI/CD, 아키텍처, 코딩·데이터·화면 규칙, 보안, 테스트·검수, 배포·운영, 일정, 납품물, 계약 조건의 틀

※ 제품명: 에셋온 AssetOn (Asset Management System ON, 약칭 AMSO). 상표 출원 전 조회로 충돌 여부를 확인합니다.

문서	에셋온 자산관리시스템 제작지시서 v1.0
발주	주식회사 지유공간개발 대표이사 최시준
관계사	주식회사 지유코퍼레이션 (첫 고객 · 실증 현장)
일자	2026 년 11 월 2 일
관련	개발기획서 v1.0 · 기능명세서 v1.0

목차

0 문서 목적과 적용 범위

1 발주 개요

2 범위 정의
- 2.1 단계별 범위표
- 2.2 범위 밖

3 기술 스택 (확정)

4 아키텍처와 인프라 구성
- 4.1 구성도
- 4.2 Cloudflare 리소스·명명
- 4.3 환경
- 4.4 데이터 위치 원칙

5 저장소·브랜치·CI/CD
- 5.1 GitHub 구성
- 5.2 모노레포 구조
- 5.3 파이프라인

6 코딩·API 규칙
- 6.1 공통
- 6.2 API 규약
- 6.3 멀티테넌트 격리

7 데이터베이스 설계 지침

8 화면·UX 지침
- 8.1 디자인 시스템
- 8.2 화면 규칙
- 8.3 디자인 산출물

9 규칙 엔진 구현 지침

10 외부 연동 구현 지침

11 보안 요구사항

12 품질·테스트·검수
- 12.1 테스트 계층
- 12.2 테스트 데이터
- 12.3 핵심 E2E 시나리오
- 12.4 검수 절차와 게이트
- 12.5 결함 등급

13 배포·운영

14 일정·마일스톤·WBS
- 14.1 1 차 26 주
- 14.2 2 차·3 차 개요
- 14.3 주간 운영

15 납품물 목록

16 커뮤니케이션·변경 관리

17 계약·비용 조건의 틀

18 수락 기준 체크리스트

부록 A 환경 변수 · B wrangler 예시 · C PR 템플릿 · D 이슈 템플릿 · E ADR 템플릿 · F 보안 체크리스트

0 문서 목적과 적용 범위

> 이 문서는 에셋온(AssetOn) 자산관리시스템을 만드는 개발 조직(내부 개발자, 외주 파트너, AI 개발 도구를 쓰는 소규모 팀 모두)에게 "어떻게 만들 것인가"를 지시합니다. 기술 스택, 저장소 구조, 인프라, 코딩·데이터·화면 규칙, 보안, 테스트·검수, 배포·운영, 일정, 납품물, 계약 조건의 틀을 정합니다. 기능의 내용은 기능명세서가, 사업의 이유는 개발기획서가 정합니다.

0.1 적용 원칙

1. **이 문서는 지시이지 제안이 아닙니다.** "~한다"로 적힌 항목은 준수 사항입니다. 바꾸고 싶으면 변경 요청(16 장)을 거칩니다.
2. **기능 ID 가 범위입니다.** 범위표(3 장)에 적힌 기능명세서 ID 만 해당 단계의 범위이며, ID 에 없는 기능은 범위 밖입니다.
3. **끝났다는 기준이 있습니다.** 각 단계는 검수 게이트(12 장)를 통과해야 끝납니다. "구현 완료"가 아니라 "검수 통과"가 완료입니다.
4. **기록이 남아야 합니다.** 설계 결정은 ADR, 작업은 이슈, 변경은 PR, 배포는 릴리스 노트로 남깁니다. 메신저로만 결정된 사항은 결정이 아닙니다.
5. **GitHub 와 Cloudflare 가 중심입니다.** 코드·이슈·배포 파이프라인은 GitHub 에, 실행·엣지·파일·큐·배포·보안은 Cloudflare 에 둡니다. 기록 데이터(개인정보·계약·금액)는 국내 리전 PostgreSQL 에 둡니다(4 장). 그 밖의 서비스는 어댑터 뒤에만 둡니다.

0.2 관련 문서와 우선순위

문서 간 내용이 다르면 제작지시서(어떻게) → 기능명세서(무엇을) → 개발기획서(왜) 순으로 구체적인 문서가 우선합니다. 단, 범위와 우선순위(P1~P3)는 기능명세서가 기준이고, 요금·사업 조건은 개발기획서가 기준입니다.

1 발주 개요

항목	내용
발주자	주식회사 지유공간개발 (대표이사 최시준)
제품	에셋온(AssetOn) 자산관리시스템 — 기능명세서 v1.0 기준
첫 고객·실증 현장	주식회사 지유코퍼레이션 (첫 고객 · 실증 현장). 관리 건물 중 2~3 동을 파일럿으로 지정
개발 조직(안)	제품 책임자(PO) 1 — 발주자 대표 / 기술 책임자(TL) 1 / 풀스택 개발 2~3 / 디자이너 1(파트타임) / QA 1(파트타임). 외주 파트너를 쓰는 경우 TL 과 QA 는 발주자 측 또는 독립 인력
계약 형태(안)	단계별 산출물 검수 계약. 1 차(MVP) → 2 차 → 3 차. 각 단계는 범위표·일정·검수 기준이 붙은 발주서로 확정
기간(안)	1 차 26 주, 2 차 26 주, 3 차 26 주 (14 장)
납품 방식	GitHub 조직 내 저장소(발주자 소유)에 직접 커밋. 별도 파일 납품은 문서·디자인 원본만
지식재산	산출물 일체는 발주자 소유. 오픈소스 라이선스 준수 목록 제출(17 장)

2 범위 정의

> 단계별 범위는 기능명세서의 기능 ID 로 정합니다. 1 차(MVP)는 지유코퍼레이션 파일럿 건물에서 종이 없이 한 달 운영할 수 있는 범위, 2 차는 외부 관리회사에 팔 수 있는 범위, 3 차는 AM·연결·확장입니다.

2.1 단계별 범위표

모듈군	1 차 (MVP, 0~6 개월)	2 차 (7~12 개월)	3 차 (13~18 개월)
CM 공통	CM-01~17, CM-20 (CM-16 은 표준 리포트만)	CM-16 사용자 정의 리포트	CM-18 다국어, CM-19 공개 API·웹훅
FM 시설관리	FM-01, 02, 04, 05, 06, 07, 14	FM-03, 08, 09, 10, 11, 13, 16, 17	FM-12, 15, IoT 어댑터
PM 자산운영	PM-01, 02, 03, 04, 05, 06, 07, 08, 13	PM-09, 10, 11, 12, 14(엑셀), 15	PM-14 회계 API
AM 자산관리	—	AM-01, 02, 03, 07	AM-04, 05, 06, 08, 09
BD 영업·견적	BD-01 (GU System 견적 모듈 이식)	BD-02, 03, 04	—
PT 포털	PT-01(숫자·보고서·문서), PT-02	PT-01 승인, PT-03, PT-04	—
SA 플랫폼	SA-01(후불 청구·세금계산서), SA-04, SA-05, SA-06, SA-08(헬프센터)	SA-01 카드 정기결제, SA-02, SA-03, SA-07, SA-08 티켓	—
WEB 홈페이지	WEB-01~05, 07, 09, 10 (출시 전 완료)	WEB-06, 08	—
화면	오피스 36 · 워크 14 · 오너 4 · 테넌트 6 · 홈페이지 12	오피스 +4 · 오너 +2 · 파트너 4 · 콘솔 4	—

2.2 범위 밖 (명시)

- 급여 계산·명세서 발행, 4 대보험 신고 — 근로시간 집계까지만 하고 급여 프로그램·노무사에 엑셀로 전달한다.
- 회계 장부·결산 — 원장 전달용 데이터까지. 회계 프로그램은 연동 대상.
- 주차·출입 장비 제어, IoT 센서 하드웨어 — 어댑터 인터페이스만 정의.
- 임대 매물 광고 플랫폼 연동, 부동산 중개 기능 — 공실 안내문·공유 링크까지.
- 네이티브 앱(앱스토어 배포) — PWA 로 대체. 3 차 이후 수요 확인 시 별도 발주.
- 고객이 작성하는 코드 실행(플러그인) — Workers for Platforms 불필요.

3 기술 스택 (확정)

> 스택은 아래로 확정합니다. 대안이 더 낫다고 판단되면 ADR 을 써서 변경 요청을 하되, 승인 전에는 아래를 따릅니다. 선택의 이유는 "작은 팀이 오래 유지할 수 있는가", "Cloudflare·GitHub 안에서 돌아가는가", "국내 데이터 위치를 지킬 수 있는가"입니다.

계층	확정 스택	이유 · 주의
언어	TypeScript (strict). Node 22 LTS 도구 체인, pnpm 10, Turborepo	프런트·백엔드·규칙 엔진을 한 언어로. 타입이 곧 문서
API 서버	Cloudflare Workers + Hono. 검증 Zod. OpenAPI 생성 (hono-openapi)	Workers Paid 플랜. 요청당 CPU 30 초 기본, 긴 작업은 Queues·Workflows 로 분리
인증	Better Auth (이메일·비밀번호, 휴대폰 OTP, 2FA, organization 플러그인) — Workers 에서 nodejs_compat 플래그	세션은 DB + KV 캐시. 외부 사용자(건물주·임차사)는 별도 인증 흐름(링크+OTP). Cloudflare Access 는 운영 콘솔에만
데이터베이스	PostgreSQL 16 — Supabase (서울 리전, Pro 플랜 + PITR 애드온). Workers 에서 Hyperdrive 경유. ORM Drizzle, 마이그레이션 drizzle-kit	기록 데이터는 국내 리전에 둔다(개인정보·계약·금액). 테넌트 격리는 tenant_id 필수 + Postgres RLS. Supabase 의 자동 REST·클라이언트 직접 접근은 사용하지 않는다(API 만 경유)
파일 저장	개인정보가 포함될 수 있는 문서(계약서·고지서·증빙·신분 관련) → Supabase Storage(서울). 현장 사진·도면·내보내기·백업 아카이브 → Cloudflare R2(location hint apac)	Cloudflare 저장소는 한국 내 저장을 보장하지 않으므로 용도로 분리. 모두 서명 URL(만료 10 분)로만 접근
캐시·설정	Cloudflare KV — 세션 캐시, 기능 플래그, 테넌트 설정 스냅샷, 공개 규칙 표	쓰기 빈도 낮은 데이터만. 원본은 DB
비동기·배치	Cloudflare Queues(알림 발송, PDF 생성, 가져오기 반영, 웹훅 처리) + Workflows(월 관리비 산정·청구·월간 보고서 생성·구독 청구) + Cron Triggers(기한 알림·연체 단계·검침 마감)	모든 소비자는 멱등. 실패는 DLQ(dead letter queue)로. Workflows 는 스텝 단위 재시도
실시간·조정	Durable Objects(SQLite) — 동시 편집 락, 전역 레이트리밋, 가져오기 진행률	필요한 곳에만. 기본 데이터 저장소로 쓰지 않는다
PDF	Cloudflare Browser Rendering — HTML 템플릿(React → 정적 HTML) → PDF. A4 인쇄 CSS, 한글 폰트 임베드 (Pretendard 서브셋)	월 포함 시간 초과 시 종량. 긴 보고서는 큐에서 생성 후 저장
프런트엔드 앱	React 19 + TypeScript + Vite, React Router v7(라이브러리 모드 SPA), TanStack Query, Zustand, react-hook-form + Zod, Tailwind CSS v4 + shadcn/ui, i18next, 차트 Recharts, 표 TanStack Table	오피스·워크·오너·테넌트·콘솔 5 개 앱이 packages/ui 를 공유. Workers Static Assets 로 배포(앱당 Worker 1 개)

계층	확정 스택	이유 · 주의
PWA · 오프라인	vite-plugin-pwa(Workbox), IndexedDB(Dexie)로 오프라인 큐, 백그라운드 동기화	워크 앱 필수, 오피스는 선택. 충돌 규칙: 서버 우선 + 사용자 확인
공개 홈페이지	Astro(정적 생성) + 체험판 위젯은 React 아일랜드. Workers Static Assets	SEO · 속도 우선. 폼은 Worker API + Turnstile
외부 연동	packages/adapters — 인터페이스(TS) + 사업자별 구현. 알림톡(공식 딜러사 API), SMS, 이메일(Resend 또는 Cloudflare Email Sending), PG(토스페이먼츠 — 빌링키 · 가상계좌, 또는 포트원), 전자세금계산서 ASP, 전자계약, OCR, 사업자번호 · 건축물대장 · 주소 API	사업자 교체 시 구현체만 교체. 샌드박스 키는 staging 에만
디자인	Figma(컴포넌트 라이브러리 = shadcn 테마 반영), 디자인 토큰(JSON) → Tailwind 설정으로 생성	9 장 디자인 지침
모니터링	Workers Logs(구조화 JSON) + Sentry(프런트 · API 오류) + Cloudflare Health Checks(가용성) + Better Stack(상태 페이지)	개인정보는 로그에 남기지 않는다
테스트	Vitest(단위 · 통합), Playwright(E2E · 브라우저 매트릭스 · 스크린샷), k6(성능), axe(접근성)	12 장
CI/CD	GitHub Actions(검사 · 테스트 · 마이그레이션 · 프로덕션 배포) + Cloudflare Workers Builds(PR 프리뷰 · 스테이징 자동 배포) + wrangler	5 장

> **하지 않는 것**
> Cloudflare Pages(신규 프로젝트는 Workers 정적 자산 사용), Workers for Platforms(고객 코드 실행 불필요), Supabase 클라이언트의 브라우저 직접 접근(모든 데이터는 API 경유), 서버 상주형 VM(상태 없는 Workers 만), ORM 없는 문자열 SQL(Drizzle 만, 예외는 ADR).

4 아키텍처와 인프라 구성

> 구성은 "엣지에서 실행하고, 국내에 기록하고, 큐로 미룬다"는 세 문장으로 요약됩니다. 모든 요청은 Cloudflare Workers 에서 처리되고, 기록은 서울 리전 PostgreSQL 에 남으며, 무거운 일은 Queues·Workflows 가 맡습니다.

4.1 구성도

계층	구성 요소	역할
사용자	오피스 PC 웹 · 워크 PWA · 오너 모바일 웹 · 테넌트(카카오 알림톡 링크) · 파트너 · 콘솔 · 공개 홈페이지	HTTPS 로 Cloudflare 엣지에 접속
Cloudflare 엣지 보안	WAF · Rate Limiting · Turnstile · Cloudflare Access(콘솔) · Cloudflare for SaaS(고객 도메인·인증서)	봇·남용 차단, 운영자 SSO, 관리회사별 도메인
Cloudflare 앱 호스팅	Workers Static Assets — office / work / owner / tenant / console / web (Worker 1 개씩)	정적 자산 무료·무제한, PR 프리뷰·스테이징 자동 배포
Cloudflare API	Worker API(Hono + TypeScript) · Better Auth · KV(세션·플래그·설정 스냅샷) · Durable Objects(편집 락·전역 레이트리밋·진행률)	모든 데이터 접근의 유일한 경로. 테넌트 가드·권한 선언
Cloudflare 비동기·배치	Queues(알림·PDF·가져오기·웹훅, DLQ) · Workflows(관리비 산정·구독 청구·월간 보고서) · Cron(기한 알림·연체 단계·검침 마감)	요청 시간 제한을 넘는 일은 모두 여기로. 멱등·재시도
Cloudflare 파일·PDF·관측	R2(사진·도면·아카이브, apac hint) · Browser Rendering(HTML → PDF) · Workers Logs → Sentry · Health Checks	개인정보 미포함 파일만 R2. 로그에 PII 없음
국내 리전 기록 데이터	Supabase PostgreSQL(서울, ap-northeast-2) — Hyperdrive 경유 · Supabase Storage(개인정보 포함 문서) · PITR 7 일 + 일 백업 + 주 1 회 R2 암호화 보관	테넌트·사용자·건물·계약·관리비·수납·작업·점검·근무·감사 로그의 원본
어댑터(외부 서비스)	알림톡·SMS·이메일 | PG(빌링키·가상계좌) | 전자세금계산서 ASP | 전자계약 | OCR | 사업자번호·건축물대장·주소·지도 API	인터페이스 뒤의 구현체. 사업자 교체 가능

요청은 위에서 아래로, 기록은 국내 리전에, 무거운 일은 큐로. 캐시·파일 일부만 Cloudflare 에 남고 원본은 항상 국내 DB 에 있습니다.

4.2 Cloudflare 리소스 목록과 명명

리소스	이름(prod / staging)	용도	설정 요점
Worker	asseton-api / asseton-api-staging	API	Hono, nodejs_compat, 바인딩: HYPERDRIVE, KV, R2, QUEUE_*, WORKFLOW_*, BROWSER, RATE_LIMITER

리소스	이름(prod / staging)	용도	설정 요점
Worker(정적)	asseton-office, -work, -owner, -tenant, -console, -web (+ -staging)	앱 호스팅	Static Assets, SPA fallback(index.html), 캐시 헤더(해시 파일 1년·HTML no-cache)
Hyperdrive	asseton-db / asseton-db-staging	Postgres 연결 풀	Supabase 세션 풀러 주소, 쿼리 캐시 OFF(업무 데이터)
KV	asseton-kv / -staging	세션·플래그·설정	TTL 명시, 값 1MB 이하
R2	asseton-media / -staging	사진·도면·아카이브	location hint apac, 공개 접근 없음, 서명 URL, 수명주기(아카이브 1 년 후 IA)
Queues	asseton-notify, asseton-pdf, asseton-import, asseton-webhook (+ DLQ 각 1)	비동기	배치 10~50, 재시도 5, DLQ 보존 14 일
Workflows	fee-run, billing-run, monthly-report	배치	스텝별 재시도, 멱등 키(테넌트·건물·귀속월)
Cron	매일 06:00 KST 기한 알림 / 매일 00:10 연체 단계 / 매월 1 일 검침 마감 / 매시 헬스	스케줄	UTC 로 환산해 등록(KST 06:00 = UTC 21:00 전일)
Durable Objects	EditLock, GlobalRateLimit, ImportProgress	조정	SQLite 백엔드, location hint apac-ne
Browser Rendering	—	PDF	템플릿은 API 가 생성한 서명 HTML URL
Cloudflare for SaaS	asseton.kr 존(가칭)	고객 도메인	fallback origin = asseton-owner/tenant, 100 hostname 포함
Access	console.asseton.kr	운영 콘솔 SSO	Google Workspace 또는 GitHub IdP, 2FA 강제, 세션 8 시간
Turnstile	가입·로그인·체험판 폼	봇 차단	managed 모드
WAF·Rate Limiting	로그인 10 회/10 분/IP, API 600 회/분/토큰, 체험판 60 회/시/IP	보호	Pro 플랜 이상 권장(규칙 수)
Health Checks	api/health, 각 앱 /	가용성	실패 시 알림(이메일·알림톡)

도메인 "asseton.kr"은 가칭입니다. 상표·도메인 확정 전까지는 Workers 기본 도메인(*.workers.dev)으로 개발하고, 확정 후 일괄 전환합니다.

4.3 환경

환경	용도	구성	데이터
local	개발자 PC	wrangler dev(원격 바인딩 또는 로컬 에뮬레이션), Supabase 로컬(Docker) 또는 dev 프로젝트	시드 데이터(가짜 회사 2 곳·건물 5 동)

환경	용도	구성	데이터
preview	PR 별 확인	Workers Builds 가 PR 마다 프리뷰 URL 생성, staging DB 공유(읽기 위주) 또는 브랜치 DB	스테이징 데이터
staging	통합 테스트·검수	main 브랜치 자동 배포. 외부 연동은 샌드박스 키	파일럿 데이터 복제본(개인정보 마스킹)
production	실서비스	태그(vX.Y.Z) 배포 + 수동 승인. 외부 연동 실키	실데이터. PITR·일 백업

4.4 데이터 위치와 흐름 원칙

- **기록 데이터(원본)** — 테넌트·사용자·건물·임차사·계약·관리비·수납·작업·점검·근무·감사 로그: 서울 리전 PostgreSQL 만. Cloudflare 에는 복제·캐시 외 원본을 두지 않는다.
- **캐시** — KV·DO 에는 세션, 플래그, 설정 스냅샷, 진행률처럼 재생성 가능한 데이터만. TTL 필수.
- **파일** — 개인정보 포함 가능 문서는 Supabase Storage(서울). 사진·도면·아카이브는 R2(apac). 파일 메타데이터(경로·해시·크기)는 DB.
- **로그** — Workers Logs·Sentry 에는 식별자(ID)만 남기고 이름·연락처·금액 본문은 남기지 않는다.
- **국외 처리 공개** — 컴퓨트·캐시·파일 일부가 국외 인프라를 거치므로 개인정보처리방침에 국외 처리위탁(사업자·국가·항목·목적)을 공개한다. 문구는 법률 자문 후 확정.

5 저장소·브랜치·CI/CD

5.1 GitHub 구성

항목	지시
조직·저장소	발주자 소유 GitHub 조직(예: naadaa87 또는 신설 조직) 아래 비공개 모노레포 1 개: `asseton`. 디자인·문서는 같은 저장소 `docs/`·`design/`
플랜	GitHub Team(사용자당 과금). 비공개 저장소 Actions 포함 시간 사용. Dependabot 활성. CodeQL 은 플랜 확인 후 (Code Security 별도 과금)
브랜치	`main` = 스테이징 자동 배포 · 보호(리뷰 1 인 이상, 상태 검사 필수, 강제 푸시 금지). 작업 브랜치 `feat/FM-04-legal-calendar`, `fix/…`, `chore/…`. 태그 `v1.2.3` = 프로덕션 릴리스
PR 규칙	기능 ID 를 제목에(예: "FM-04: 법정점검 규칙 엔진"). 템플릿(부록 C) 필수. 스크린샷·테스트 결과 첨부. 500 줄 초과 PR 은 분할. 셀프 머지 금지
커밋	Conventional Commits(feat/fix/chore/docs/refactor/test). 메시지에 기능 ID
이슈	GitHub Issues + Projects(칸반). 라벨: 모듈군(CM/FM/PM/…), 우선(P1~P3), 유형(기능/결함/기술부채), 단계(1 차/2 차/3 차). 결함은 등급(12.6)
결정 기록	`docs/adr/NNNN-제목.md` (부록 E 템플릿). 스택·데이터·보안·연동 결정은 반드시 ADR
시크릿	GitHub Environments(staging/production)의 Secrets 에만. 코드·wrangler.toml 에 비밀값 금지. Cloudflare API 토큰은 최소 권한(Workers·KV·R2·Queues·D1 편집)

5.2 모노레포 구조

```
asseton/
  apps/
    api/          Hono Worker (라우트 · 서비스 · 어댑터 바인딩 · Workflows · Cron)
    office/       React SPA (본사·관리소장)
    work/         React PWA (현장)
    owner/        React SPA (건물주·AM)
    tenant/       React 모바일 웹 (임차사)
    console/      React SPA (운영자)
    web/          Astro 공개 홈페이지 + 체험판
  packages/
    db/           Drizzle 스키마 · 마이그레이션 · 시드 · RLS 정책 SQL
    rules/        규칙 엔진 (관리비 배분 · 연체 · 승인 · 법정점검 · 근로시간 · 견적) — 순수 TS, 100% 테스트
    adapters/     외부 연동 인터페이스 + 구현체 (alimtalk, sms, email, pg, taxinvoice, esign, ocr, gov)
    ui/           공용 컴포넌트 (shadcn 기반) · 디자인 토큰 · 인쇄 템플릿
    shared/       타입 · 유틸 · i18n 리소스 · 상수(법정 항목 코드 등)
    config/       eslint · tsconfig · tailwind · prettier
  docs/           ADR · API(OpenAPI) · 운영 매뉴얼 · 검수표
  design/         Figma 내보내기 · 토큰 JSON
  .github/workflows/   ci.yml · migrate.yml · deploy-prod.yml
```

```
turbo.json  pnpm-workspace.yaml  wrangler/*.toml
```

5.3 파이프라인

트리거	워크플로	단계	결과
PR 열림·갱신	ci.yml (Actions)	pnpm install → lint → typecheck → 단위·통합 테스트(규칙 엔진 커버리지 게이트) → 빌드 → E2E(스모크, Playwright)	상태 검사 통과해야 머지 가능
PR 열림·갱신	Workers Builds	각 앱 프리뷰 배포 → PR 코멘트에 URL	리뷰어가 화면 확인
main 머지	migrate.yml + Workers Builds	drizzle 마이그레이션 staging 적용 → 앱·API staging 배포 → 스모크 테스트	스테이징 최신화
태그 v*	deploy-prod.yml (workflow_dispatch 승인 포함)	릴리스 노트 생성 → 마이그레이션 prod 적용(사전 백업 확인) → wrangler deploy(점진 배포 10%→100%) → 헬스체크 → 실패 시 자동 롤백(이전 버전)	프로덕션 릴리스
매일	nightly.yml	전체 E2E, 성능 스모크, 의존성 취약점 점검, 백업 존재 확인	리포트 이슈 자동 생성

비공개 저장소에서 GitHub Environments 의 "필수 리뷰어" 게이트는 Enterprise 플랜에서만 동작합니다. Team 플랜에서는 workflow_dispatch 수동 실행 + 태그 보호 + 2 인 승인 규칙(브랜치 보호)으로 대체합니다.

6 코딩·API 규칙

6.1 공통

- TypeScript strict, `any` 금지(예외는 주석으로 사유). ESLint·Prettier 설정은 packages/config 를 따르고 CI 에서 강제.
- 폴더·파일은 기능 단위(feature-first). 모듈군 약자를 디렉터리 이름에 반영(`modules/fm/legal-inspection/`).
- 규칙(계산·판정)은 packages/rules 에만 둔다. 앱·API 에서 금액·주기를 직접 계산하지 않는다.
- 시간: 서버는 UTC ISO 8601, 화면은 Asia/Seoul. 날짜만 있는 값(귀속월·만기)은 `YYYY-MM-DD` 문자열.
- 금액: 원 단위 정수(bigint 호환). 비율은 소수점 6 자리 문자열 또는 정수 ppm. 부동소수점으로 금액을 계산하지 않는다.
- 식별자: ULID(시간 정렬 가능). 외부 노출 ID 와 내부 ID 분리하지 않음(ULID 그대로).
- 로그: 구조화 JSON(`level, ts, req_id, tenant_id, user_id, event, …`). 개인정보·비밀번호·토큰 금지.
- 기능 플래그: KV 기반 `flags:{tenant}:{key}`. 미완성 기능은 플래그 뒤에서 배포.

6.2 API 규약

항목	규칙
스타일	REST + JSON. 경로 `/v1/{module}/{resource}`. 복수형 명사. 예: `GET /v1/pm/leases?building_id=…`
인증	Bearer 세션 토큰(Better Auth). 테넌트 컨텍스트는 토큰에서 도출하고 경로·본문의 tenant_id 는 무시(불일치 시 403).
권한	라우트마다 필요한 권한(모듈·동작)과 건물 범위를 미들웨어로 선언. 선언 없는 라우트는 CI 에서 실패.
응답 봉투	성공 `{ data, meta }`, 오류 `{ error: { code, message, details[], req_id } }`. HTTP 상태는 의미대로(400/401/403/404/409/422/429/500).
페이지네이션	커서 방식 `?cursor=&limit=`(기본 50, 최대 200). 정렬은 명시 필드만.
멱등성	금액·문서를 만드는 POST(고지·세금계산서·수납·청구)는 `Idempotency-Key` 헤더 필수. 동일 키 24 시간 내 재요청은 같은 결과 반환.
검증	Zod 스키마로 입력 검증, 스키마에서 OpenAPI 생성. 검증 실패는 422 + 필드별 details.
동시성	수정은 `updated_at` 또는 버전 필드로 낙관적 잠금. 충돌 409.
파일	업로드는 서명 URL 발급(`POST /v1/files/presign`) → 직접 업로드 → 확정(`POST /v1/files/commit`). 서버 경유 업로드 금지. MIME·크기 검증.
웹훅 수신	서명 검증(사업자별), 중복 이벤트 무시(이벤트 ID 저장), 큐로 넘기고 즉시 200.
버전	`/v1` 유지. 호환 깨는 변경은 `/v2` 신설. 응답 필드 추가는 호환.

항목	규칙
속도 제한	토큰당 600 회/분, 테넌트당 6,000 회/분. 초과 429 + Retry-After.

6.3 멀티테넌트 격리

1. 모든 테넌트 테이블은 `tenant_id` 컬럼과 복합 인덱스 `(tenant_id, …)`를 가진다.
2. Drizzle 쿼리 빌더에 테넌트 가드를 두어 `tenant_id` 조건 없는 쿼리는 실행 전에 예외를 던진다(개발·테스트에서 즉시 발견).
3. Postgres RLS 를 켜고 세션 변수(`app.tenant_id`)로 정책을 건다. API 는 트랜잭션 시작 시 변수를 설정한다. 가드와 RLS 는 이중 안전장치다.
4. 외부 사용자(건물주·임차사·협력업체)는 "범위 토큰"으로 자기 자산·호실·작업만 접근한다. 범위는 토큰 발급 시 DB 에서 계산해 저장.
5. 테넌트 간 교차 접근 자동 테스트(모든 라우트 × 2 개 테넌트)를 CI 에 포함한다. 1 건이라도 실패하면 배포 불가.

7 데이터베이스 설계 지침

항목	규칙
명명	snake_case, 단수 테이블명(`lease`, `fee_run`), PK `id`(ULID text), FK `{table}_id`. 인덱스 `ix_{table}_{cols}`, 유니크 `ux_…`
공통 컬럼	`tenant_id, created_at, created_by, updated_at, updated_by, deleted_at`(소프트 삭제). 금액·계약·고지·세금계산서·수납은 소프트 삭제도 금지(취소 상태만).
타입	금액 `bigint`, 면적 `numeric(12,2)`, 비율 `numeric(12,6)`, 일시 `timestamptz`, 날짜 `date`, JSON 은 `jsonb`(구조는 Zod 로 문서화), 열거형은 `text` + CHECK 제약
마이그레이션	drizzle-kit generate → PR 에 SQL 포함 → 리뷰. 전진 전용(forward-only). 컬럼 삭제·타입 변경은 2 단계(추가·전환 → 다음 릴리스에 제거). 데이터 마이그레이션은 별도 스크립트 + 롤백 스크립트
감사	금액·계약·권한·개인정보 테이블은 트리거로 `audit_log`에 변경 전후 기록. 애플리케이션에서도 사용자·요청 ID 를 세션 변수로 전달
개인정보	휴대폰·이메일·계좌번호는 애플리케이션 레벨 암호화(AES-256-GCM, 키는 Workers Secret, 키 버전 컬럼). 검색용 해시 컬럼(HMAC) 별도. 주민등록번호는 저장하지 않는다
테넌트 데이터 분리 옵션	기본은 공유 스키마 + tenant_id + RLS. 엔터프라이즈 고객 요구 시 테넌트별 스키마 분리 가능하도록 테이블 접두를 쓰지 않고 스키마 검색 경로로 전환 가능하게 설계
플랫폼 데이터	`platform` 스키마(테넌트·플랜·구독·청구·사용량·기능 플래그·티켓)는 테넌트 스키마와 분리. 운영 콘솔만 접근
규칙 데이터	`rule_set`은 플랫폼 기본(tenant_id null) + 테넌트 재정의. 조회는 "재정의 → 기본" 순 병합. 변경 이력·적용 시작일 필수
성능	목록 쿼리는 커서 인덱스 보장. 월 산정 배치는 건물 단위 트랜잭션, 호실 200×항목 15 = 3,000 행을 `INSERT … SELECT`로. N+1 금지(리뷰 체크리스트)
백업	Supabase 일 백업 + PITR 7 일. 주 1 회 `pg_dump`를 R2(암호화)로 이중 보관 30 일. 분기 복구 훈련(스테이징에 복원·검증) 기록
용량	테넌트당 건물 500 동·호실 5 만·연 고지 60 만 건을 기준으로 인덱스·파티션 검토. 감사 로그·알림 이력은 월 파티션

8 화면·UX 지침

> 디자인의 기준은 "60 대 관리소장이 교육 1 시간으로 쓰고, 현장 근무자가 장갑 낀 손으로 입력하고, 건물주가 숫자 다섯 개를 10 초 안에 읽는 것"입니다. 예쁜 것보다 읽히는 것, 새로운 것보다 익숙한 것을 고릅니다.

8.1 디자인 시스템

항목	지시
색	바탕 흰색(#FFFFFF)·연회색(#F3F5F8). 기본 텍스트 #1F2937. 주색 네이비 #0F1C36. 포인트 그린 #17A35F(확인·완료·주요 버튼). 경고 앰버 #D97706, 오류 레드 #B91C1C, 정보 블루 #2563EB. 화이트라벨 시 주색·포인트만 테넌트 값으로 교체
글꼴	Pretendard(자체 호스팅, 서브셋). 본문 15px(오피스)·17px(워크·오너·테넌트), 큰 글씨 모드 +2px. 숫자는 tabular-nums
간격·크기	8px 그리드. 터치 영역 최소 44×44px(워크·테넌트·오너). 표 행 높이 44px(오피스)·56px(모바일)
컴포넌트	shadcn/ui 기반 packages/ui. 버튼(주·보조·위험·링크), 입력(텍스트·숫자·금액·면적·날짜·선택·검색 선택·파일), 표(정렬·필터·열 선택·고정 열), 카드, 드로어(상세), 다이얼로그(확인), 토스트, 배지(상태), 빈 상태, 스켈레톤
상태 색 규칙	예정 회색 / 진행 블루 / 완료 그린 / 지연 앰버 / 실패·미이행 레드. 전 모듈 동일
아이콘	Lucide. 아이콘만으로 의미 전달 금지(텍스트 병기)
다크 모드	지원하지 않음(현장 가독성 우선). 인쇄 스타일은 별도

8.2 화면 규칙

- **종이 양식의 순서를 따른다** — 일지·점검표·견적서·고지서 화면의 항목 순서는 테넌트가 쓰던 양식과 같게 한다. 양식 템플릿 편집 화면 제공.
- **한 화면 한 과업** — 워크 앱은 화면당 하나의 입력 과업. 뒤로 가기로 길을 잃지 않게 단계 표시.
- **기본값과 자동 채움** — 전일 복사, 최근 값, 건물·호실 자동 선택. 타이핑을 최소화한다.
- **저장은 자동, 확정은 명시** — 입력은 자동 저장(초안), 금액·발송·승인은 명시적 확인 다이얼로그(되돌릴 수 없는 작업은 빨간 버튼 + 요약).
- **숫자는 근거로 이어진다** — 대시보드·보고서의 숫자는 클릭하면 근거 목록으로 이동한다.
- **오류는 현장 언어로** — "422 Unprocessable"이 아니라 "계약 종료일이 시작일보다 앞섭니다. 종료일을 확인해 주세요."
- **오프라인 표시** — 워크 앱은 상단에 오프라인·동기화 대기 건수를 항상 표시.
- **표 우선, 카드 보조** — 오피스는 표가 기본. 모바일은 카드.

- **인쇄·PDF** — A4 세로 기본, 견적서·근무표는 가로. 머리말에 회사 로고·문서명·건물·기간, 바닥에 페이지·발행일·발행자. 미리보기와 PDF 가 동일해야 한다.
- **접근성** — 명도 대비 4.5:1, 폼 라벨 연결, 키보드 조작, 포커스 표시. axe 자동 검사 통과.

8.3 디자인 산출물

- Figma: 디자인 토큰, 컴포넌트 라이브러리, 1 차 범위 화면 전부(오피스 36·워크 14·오너 4·테넌트 6·홈페이지 12)의 PC·모바일 시안, 인쇄 양식 5 종(견적서·고지서·일지·근무표·월간 보고서).
- 토큰 JSON → Tailwind 설정 자동 생성 스크립트. 디자인과 코드의 색·간격이 다르면 결함.
- 디자인 검수: PO + 지유코퍼레이션 관리소장 1 인이 워크 앱 시안을 실제 현장 시나리오로 검토(종이 양식과 나란히).

9 규칙 엔진 구현 지침

> 관리비 배분, 연체, 승인, 법정점검, 근로시간, 견적은 모두 packages/rules 의 순수 함수로 구현합니다. 입력은 데이터와 규칙 설정, 출력은 결과와 "계산 근거"입니다. 근거가 없는 숫자는 화면에 내보내지 않습니다.

엔진	입력	출력	테스트 기준
fee (관리비 배분)	항목·배분 기준·호실 면적·검침·계약 조건·반올림 규칙	호실별 항목별 금액, 조정 내역, 경고	합계 일치(총액 = 호실 합), 기준별 케이스 30종, 공실·정액·렌트프리 조합
delinquency (연체)	고지·납부 이력·단계 설정·요율	단계, 연체료, 다음 액션	휴일 처리, 부분 납부 충당, 상한
approval (승인)	금액·CAPEX 여부·계약 승인 구간·역할	승인 단계 목록	구간 경계값, 관리계약 재정의
legal (법정점검)	건물 속성·규칙 표·최근 수행 이력	의무 항목·다음 기한·담당 기관	규칙 표의 모든 조건식, 해당 없음 처리, 기한 계산(사용승인일 기준)
worktime (근로시간)	교대 패턴·근무 기록·감시단속 여부	월 근로·야간·연장·휴일 시간	12.5 규칙 케이스, 교대 형태 3 종, 월 길이
quote (견적)	직책 행·요율 프리셋·기타비용·반올림 설정	갑지·을지 전 항목, 검증 경고	세종 IT 타워 견적서(16 직책)와 원 단위 일치 골든 테스트, 요율 변경 시 재검증

- 규칙 설정은 Zod 스키마로 정의하고, 설정 화면(CM-15)은 스키마에서 폼을 생성한다. 설정 저장 전 스키마 검증.
- 모든 엔진은 "설명(explain)" 출력을 가진다 — 항목별 공식·입력값·중간값. 산정 근거표·견적 산출내역은 이 출력을 렌더링한다.
- 엔진 버전과 규칙 설정 버전을 결과에 저장한다. 과거 산정 결과를 다시 계산해도 같은 값이 나와야 한다.
- 커버리지 게이트: packages/rules 는 분기 커버리지 95% 이상. 미달 시 CI 실패.

10 외부 연동 구현 지침

항목	지시
인터페이스	packages/adapters 에 용도별 인터페이스를 둔다: `MessagingProvider`(alimtalk/sms/email), `PaymentProvider`(billingKey, virtualAccount, webhook), `TaxInvoiceProvider`, `ESignProvider`, `OcrProvider`, `GovDataProvider`(bizno, building, address). 구현체는 사업자별 디렉터리
선택	구현체는 환경 변수·테넌트 설정으로 선택. 테넌트별 다른 사업자(예: 테넌트 자체 PG 계약) 허용
샌드박스	모든 사업자의 샌드박스 키는 staging 에만. production 키는 Cloudflare Secrets. 로컬은 목(mock) 구현체 사용
신뢰성	호출은 큐 소비자에서. 재시도는 지수 백오프(최대 5 회), 영구 실패는 DLQ + 운영 알림 + 테넌트 알림센터 표시. 멱등 키로 중복 발송 방지
웹훅	서명·타임스탬프 검증, 이벤트 ID 중복 체크, 원문 저장(30 일), 처리 결과 기록
비용 계량	발송·발행·호출 1 건마다 `usage_event` 기록(테넌트·유형·수량·원가). 청구와 1:1 대조
알림톡	템플릿은 코드에 상수로 두지 않고 DB(템플릿 코드·변수 스키마·승인 상태) 관리. 정보성 메시지만. 실패 시 SMS 대체는 테넌트 설정
PG	빌링키는 PG 에만 저장(토큰만 보관). 가상계좌 입금 웹훅은 수납 매칭 큐로. 환불·취소는 승인 로그 필수
세금계산서	발행 전 사업자 상태 재검증, 발행 후 승인번호 저장, 전송 기한(익일) 미전송 알림
OCR	추출값은 "초안" 플래그와 신뢰도 점수를 저장. 사람이 확정하기 전에는 계산에 쓰지 않는다
공공 API	응답 캐시(건축물대장 30 일, 사업자 상태 1 일). 장애 시 수동 입력 경로 보장
계약·문서	각 연동의 계약서·요금표·API 문서 버전을 `docs/integrations/`에 보관

11 보안 요구사항

영역	요구
기준	OWASP ASVS Level 2 를 목표로 한다. 출시 전 외부 모의해킹 1 회(범위: 인증·권한·테넌트 격리·파일·결제 웹훅)
인증	비밀번호 10 자 이상·유출 목록 대조, 실패 10 회 잠금(15 분), 2FA(테넌트 관리자·경리·운영자 필수), 세션 토큰 회전, 로그아웃 시 서버 세션 폐기, 새 기기 로그인 알림
권한	서버 측 권한 검사 100%(라우트 선언 강제). 프런트의 숨김은 편의일 뿐. 승인 한도는 서버에서 재검증
테넌트 격리	6.3. 교차 접근 자동 테스트 필수
전송·저장	TLS 1.2+ 강제(HSTS), DB·스토리지 저장 암호화, 개인정보 필드 애플리케이션 암호화(7 장), 백업 암호화
비밀 관리	Cloudflare Secrets·GitHub Secrets 만. 분기별 키 회전 절차 문서화. 저장소 내 비밀 탐지(gitleaks) CI
입력·출력	Zod 검증, 출력 인코딩, CSP(스크립트 self + 필요한 SDK 만), CSRF(SameSite + 토큰), SQL 은 ORM 파라미터 바인딩만
파일	MIME·확장자·크기 검증, 이미지 재인코딩, 문서는 PDF 변환 후 미리보기, 서명 URL 10 분, 다운로드 로그
속도 제한·봇	로그인·OTP·가입·체험판에 Turnstile + 레이트리밋. API 토큰별 한도
로그·감사	감사 로그 3 년 불변, 접근 로그 1 년, 운영자 위임 접근은 전 조회 기록. 로그에 PII 금지
의존성	Dependabot 주간, 심각(critical) 취약점은 7 일 내 패치. SBOM 생성
개인정보	최소 수집, 보유 기간 자동 적용(만료 데이터 일괄 파기 배치), 열람·정정·삭제 요청 처리 화면(SA-06), 처리위탁·국외 처리 공개, 유출 대응 절차(72 시간 통지 포함) 문서화·훈련
운영 콘솔	Cloudflare Access(IdP + 2FA), IP 제한, 위임 접근은 테넌트 승인·시간 제한·기록
출시 체크	보안 체크리스트(부록 F) 전 항목 통과 + 모의해킹 지적사항 조치 완료가 출시 조건

12 품질·테스트·검수

12.1 테스트 계층

계층	도구	범위	게이트
단위	Vitest	규칙 엔진, 유틸, 어댑터 매핑	rules 분기 95%, 그 외 70%
통합	Vitest + 테스트 DB(Supabase 로컬)	API 라우트(권한·검증·트랜잭션), 큐 소비자, Workflows 스텝	주요 라우트 100% 1 건 이상, 테넌트 교차 테스트 전 라우트
E2E	Playwright	핵심 시나리오 12 종(12.3), 브라우저 매트릭스, 모바일 뷰포트, 오프라인 시나리오	PR 스모크 5 종, nightly 전체
시각 회귀	Playwright 스크린샷	인쇄 양식 5 종, 주요 화면 20 종	차이 발생 시 승인 필요
성능	k6	목록 API p95 500ms(동시 200), 월 산정 1,000 동 60 분, PDF 30 초	릴리스 전 1 회, 기준 미달 시 출시 보류
접근성	axe-core	전 화면 자동 검사	심각 위반 0
보안	gitleaks, pnpm audit, 외부 모의해킹	11 장	출시 전

12.2 테스트 데이터

- 시드: 가짜 관리회사 2 곳(격리 테스트용), 건물 5 동(오피스·근생·물류·집합건물·병원), 호실 120, 임대차 90, 설비 200, 인력 40, 12 개월 관리비·수납 이력.
- 골든 데이터: 세종 IT 타워 견적서(원 단위 일치), 지유코퍼레이션 실제 양식 10 종(개인정보 마스킹)으로 가져오기·출력 비교.
- 개인정보: 테스트 데이터에 실제 개인정보 금지. 스테이징의 파일럿 복제본은 마스킹 스크립트 통과 후에만.

12.3 핵심 E2E 시나리오

1. 관리회사 가입 → 온보딩 마법사 → 엑셀 이관(건물·호실·임대차) → 첫 고지서 발송
2. 현장 근무자 PIN 로그인(오프라인) → 점검 체크리스트 입력 → 이상 항목 → 작업지시 자동 생성 → 동기화
3. 임차사 알림톡 링크 → 민원 접수 → 배정 → 처리 → 완료 알림 → 만족도
4. 건물 조건 입력 → 법정점검 항목 자동 생성 → D-30 알림 → 결과 보고서 첨부 → 월간 보고서 반영
5. 근무표 생성(3 교대) → 출퇴근 기록 → 월 근로시간 집계 → 엑셀 출력(견적 엔진과 동일 시간 산출 검증)
6. 월 관리비 산정(검침 반영) → 이상치 경고 → 확정 → 고지서 발송 → 가상계좌 입금 웹훅 → 자동 매칭 → 수납률 반영
7. 연체 7 일 → 알림톡 → 30 일 → 독촉장 PDF → 연체료 계산 → 보증금 공제 시뮬레이션

8. 세금계산서 월 일괄 발행 → ASP 전송 → 승인번호 저장 → 실패 재시도
9. 임대차 만기 D-90 → 갱신 협상 기록 → 건물주 승인(오너 포털) → 갱신 계약 생성
10. 월간 보고서 자동 생성 → 편집 → 승인 → 발행 → 건물주 열람 로그
11. 견적서 작성(16 직책) → 발송 전 확인 경고 → 엑셀·PDF 출력 → 골든 값 일치
12. 테넌트 A 사용자가 테넌트 B 데이터에 접근 시도 → 403 → 감사 로그 기록

12.4 검수 절차와 게이트

게이트	시점	통과 조건
G0 설계 승인	1 차 착수 2 주	ADR 10 건 이상(스택·DB·인증·격리·연동·PDF·오프라인·규칙 엔진·배포·백업), ER 다이어그램, API 목록, Figma 화면 50%
G1 코어 검수	1 차 8 주	CM-01~17 통과, 가져오기 골든 양식 10 종 성공, 교차 접근 테스트 0 건 실패
G2 FM 검수	1 차 14 주	FM 1 차 범위 통과, 파일럿 건물 1 동에서 관리소장이 워크 앱으로 1 주 입력(입력률 80%)
G3 PM 검수	1 차 20 주	PM 1 차 범위 통과, 파일럿 건물 관리비 1 개월 산정·고지·수납 재현(기존 엑셀과 일치)
G4 출시 검수	1 차 26 주	12.1 전 게이트, 보안 체크리스트, 모의해킹 조치, 파일럿 2~3 동 종이 없이 한 달 운영(입력률 90%, 임차사 요청 50% 시스템 접수), 운영 매뉴얼·헬프센터·약관 게시
G5·G6	2 차·3 차 말	해당 단계 범위표 전 기능 통과 + 외부 테넌트 1 곳 이상 실사용 검수

검수는 발주자 PO 와 지유코퍼레이션 현장 담당자가 함께 수행하며, 검수표(기능 ID × 시나리오 × 결과)를 `docs/acceptance/`에 남깁니다. 검수 요청 후 10 영업일 내 결과를 통보하고, 지적 사항은 등급별 기한 안에 조치합니다.

12.5 결함 등급

등급	정의	조치 기한	출시 조건
S1 치명	데이터 손실·오염, 금액 오류, 테넌트 격리 실패, 보안 취약점, 서비스 중단	24 시간	0 건
S2 심각	핵심 시나리오 수행 불가, 우회 없음	3 영업일	0 건
S3 보통	기능 오류, 우회 가능	10 영업일	5 건 이하(조치 계획 첨부)
S4 경미	화면·문구·편의	다음 릴리스	제한 없음

13 배포·운영

항목	지시
릴리스	시맨틱 버전. 2 주 단위 정기 릴리스 + 긴급 패치. 릴리스 노트(사용자용 한글 + 기술 변경) 자동 생성 후 PO 검토
배포 절차	① 태그 → ② 마이그레이션(백업 확인 후) → ③ Workers 점진 배포(10% → 50% → 100%, 각 10 분 헬스 확인) → ④ 스모크 E2E → ⑤ 상태 페이지 갱신. 평일 10~16 시 외 프로덕션 배포 금지(긴급 제외)
롤백	Workers 이전 버전으로 즉시 롤백(wrangler rollback). DB 는 전진 전용이므로 호환 깨는 마이그레이션은 2 단계 원칙(7 장)으로 롤백 불필요하게 설계
모니터링	오류율·지연(p95)·큐 적체·DLQ 건수·발송 실패율·헬스체크·DB 연결 수·저장 용량. 대시보드 1 장
알림	S1 급(헬스 실패, 오류율 5%↑, DLQ 발생, 결제 웹훅 실패) → 알림톡+이메일 즉시. S2 급 → 이메일. 야간 당직 1 인
백업 검증	매일 백업 존재 확인(자동), 분기 복구 훈련(스테이징 복원 후 데이터 검증) 기록
장애 대응	심각도 판정 → 상태 페이지 공지(15 분 내) → 복구 → 24 시간 내 1 차 보고 → 5 영업일 내 사후 분석(postmortem) → 재발 방지 이슈
규칙 갱신	매년 최저임금·보험요율·법정점검 고시 추적 담당 지정. 갱신은 플랫폼 기본값 배포 + 테넌트 공지 + 적용 시작일
용량·비용	월 1 회 Cloudflare·Supabase·연동 사용량·비용 리뷰, 테넌트별 원가 산출(개발기획서 단위 경제 변수에 반영)
운영 문서	운영 매뉴얼(배포·롤백·장애·백업·키 회전·테넌트 온보딩·해지 처리), 관리자 가이드, 사용자 가이드(헬프센터 원본)

14 일정·마일스톤·WBS

> 1 차 26 주를 기준으로 적습니다. 기간은 개발 조직 규모에 따라 조정하되, 게이트의 순서와 통과 조건은 바꾸지 않습니다. 2·3 차는 1 차 종료 시점에 같은 형식으로 발주합니다.

14.1 1 차(MVP) 26 주

주차	작업 패키지	산출물	게이트
W1~2	착수: 저장소·CI·환경·인증·DB 스키마 초안·디자인 토큰·ADR	동작하는 빈 앱 6 개, 로그인, 스테이징 배포, ADR 10 건, Figma 50%	G0
W3~6	CM 코어: 회사·사용자·권한·건물·호실·설비·거래처·문서함·알림·대시보드·캘린더·설정·감사 로그	오피스 OF-01~08, 34, 35, 38	
W5~8	가져오기·내보내기, 규칙 엔진 뼈대 (fee·legal·worktime·quote), 견적 모듈 이식	OF-37, OF-31, rules 테스트	G1 (W8)
W7~12	FM: 작업지시·점검·법정점검·일지·순찰·근무표·출퇴근·민원, 워크 PWA(오프라인)	OF-09~16, WK-01~09, 13, 14	
W11~14	테넌트 창구·알림톡·PDF 파이프라인, 파일럿 1 동 현장 투입	TN-01~05, 알림 13 장 P1 전부	G2 (W14)
W13~18	PM: 관리계약·임대차·렌트롤·만기·관리비 산정·고지·수납·연체·세금계산서	OF-17~25	
W17~20	월간 보고서·오너 포털(숫자·보고서·문서)·표준 리포트	OF-28, 33, ON-01~03, 05, 리포트 14 장 P1	G3 (W20)
W19~22	플랫폼: 가입·후불 청구·세금계산서·사용량·온보딩 마법사·보안(2FA)·헬프센터	OF-36, SA-01(후불)·04·05·06·08	
W21~24	홈페이지(소개·기능·요금·체험판·가입·인사이트·약관), 성능·보안 점검, 모의해킹	WB-01~12, k6·axe·보안 리포트	
W23~26	파일럿 2~3 동 한 달 운영, 결함 조치, 운영 문서·검수	검수표, 운영 매뉴얼, 릴리스 v1.0	G4 (W26)

14.2 2 차·3 차 개요

단계	기간	핵심 작업	끝났다는 기준
2 차	27~52 주	예방정비·인력·교육·안전·사고·에너지·협력업체·미화보안, 보증금·지출 승인·공실·보험·회계 엑셀, AM 대시보드·손익·예산·투자자 보고, 제안서·파이프라인·수주 전환, 오너 승인·파트너 포털·공지, 카드 정기결제·운영 콘솔·화이트라벨·상태 페이지	외부 관리회사 2~3 곳 유료 구독, 관리비가 시스템에서 산정·고지·수납, 건물주가 앱에서 승인
3 차	53~78 주	CAPEX·롤오버·밸류에이션·데이터룸·KPI, 자재·주차, 회계 API, 다국어, 공개 API·웹훅, IoT 어댑터	프로 플랜 고객(AM 모듈) 확보, API 사용 파트너 1 곳

14.3 주간 운영

- 주간 회의 1 회(30 분): 지난주 완료 이슈, 이번 주 계획, 막힌 것, 결정 필요. 회의록은 GitHub Discussions.
- 격주 데모: 스테이징에서 PO·현장 담당자에게 시연. 피드백은 이슈로.
- 매주 금요일 스테이징 스냅샷·지표 보고(테스트 통과율, 열린 결함, 커버리지, 성능).

15 납품물 목록

구분	납품물	형식·위치	검수 기준
코드	모노레포 전체(앱 6, 패키지 6), 테스트, 시드, 마이그레이션	GitHub 저장소(발주자 소유)	CI 통과, 태그 v1.0
인프라	wrangler 설정, Cloudflare 리소스 목록·설정값, Supabase 프로젝트 설정, DNS 기록	`wrangler/*.toml`, `docs/infra/`	문서대로 재구축 가능(리허설 1 회)
설계 문서	ADR 전부, ER 다이어그램, API 문서(OpenAPI + 생성 HTML), 규칙 엔진 설명서, 어댑터 인터페이스 문서	`docs/`	최신 코드와 일치
디자인	Figma 파일(편집 권한 이전), 토큰 JSON, 아이콘·인쇄 양식 원본	`design/` + Figma	화면 50 종, 인쇄 양식 5 종
테스트	테스트 코드, 커버리지 리포트, E2E 결과, 성능·접근성·보안 리포트, 검수표	`docs/acceptance/`	12 장 게이트
운영 문서	운영 매뉴얼, 관리자 가이드, 사용자 가이드(헬프센터 원본), 장애 대응 절차, 키 회전 절차, 백업·복구 절차	`docs/ops/` + 헬프센터	운영자 1 인이 문서만으로 배포·롤백·복구 수행(리허설)
법무·약관 초안	이용약관, 개인정보처리방침, 처리위탁 계약 템플릿, SLA 초안(법률 자문 전 초안)	`docs/legal/`	법률 자문 검토용 완성도
교육	관리자 교육 1 회, 현장(관리소장) 교육 1 회, 녹화본	녹화 파일	참석자 확인
오픈소스 목록	사용 라이브러리·라이선스·버전(SBOM)	`docs/sbom.json`	GPL 계열 등 전염성 라이선스 없음

16 커뮤니케이션·변경 관리

항목	규칙
채널	이슈·PR·Discussions(GitHub)가 기록 채널. 메신저(카카오·슬랙)는 긴급 연락용이며 결정은 반드시 GitHub 에 옮긴다
결정권	범위·우선순위·요금·브랜드 = PO(발주자 대표). 기술 선택 = TL(ADR 작성, PO 승인). 현장 적합성 = 지유코퍼레이션 담당자 의견 1 순위
변경 요청(CR)	범위·일정·비용에 영향 있는 변경은 CR 이슈(배경·영향·대안·비용·일정)로 제출 → PO 승인 → 범위표·발주서 개정. 승인 전 착수 금지
응답 기한	질문 1 영업일, CR 3 영업일, 검수 결과 10 영업일
보고	주간 지표 보고(14.3), 게이트별 검수 보고서, 월 1 회 비용·사용량 보고
비밀유지	파일럿 건물·거래처·임차사 정보는 계약상 비밀. 테스트 데이터로 사용 시 마스킹

17 계약·비용 조건의 틀

> 금액은 이 문서에 적지 않습니다. 개발 조직 구성(내부·외주·혼합)에 따라 견적을 받아 발주서에 적습니다.
> 아래는 어떤 조건이 들어가야 하는지의 틀입니다.

항목	틀
대금 구조	단계별 산출물 검수 기준 지급. 예: 착수금 → 중간 게이트(G1·G2·G3) → 출시 검수(G4). 비율은 발주서에서. 검수 미통과 시 해당 지급 보류
하자보수	출시 검수 후 6~12 개월 무상 하자보수(S1·S2 결함). 범위 밖 요구는 유지보수 계약
유지보수	출시 후 월정액 유지보수(모니터링·패치·규칙 갱신·소규모 개선 N 시간) 별도 계약. 응답·복구 목표(SLA) 명시
지식재산	산출물 일체(코드·문서·디자인·데이터)는 발주자 소유. 개발사의 기존 범용 라이브러리는 비독점 영구 사용권으로 명시. 오픈소스는 라이선스 목록 제출
비밀유지	상호 NDA. 파일럿 데이터·요금·고객 정보 비밀. 계약 종료 후 3 년
변경 관리	16 장 CR 절차. CR 누적이 원 범위의 20%를 넘으면 발주서 개정
지연·해지	게이트 지연 시 통지·만회 계획, 귀책에 따른 지연 배상·해지 조건. 해지 시 산출물 인계 의무
인력	핵심 인력(TL) 교체 시 사전 협의. 외주 재하도급 금지(사전 승인 예외)
보안·개인정보	개발사는 개인정보 처리 수탁자로서 11 장 준수, 교육·서약, 접근 권한 최소화, 종료 시 데이터 파기 확인
검수 기준	12 장 게이트와 결함 등급이 계약서 별지

18 수락 기준 체크리스트 (Definition of Done)

18.1 기능 단위

- 기능명세서의 설명·규칙·우선순위와 일치한다(ID 기준).
- 단위·통합 테스트가 있고 CI 를 통과한다. 규칙이 있으면 rules 테스트가 있다.
- 권한 선언이 있고 교차 접근 테스트에 포함되었다.
- 화면이 디자인 시안·8 장 규칙과 일치한다(PC·모바일). axe 심각 위반 0.
- 오류 메시지가 현장 언어다. 로그에 PII 가 없다.
- 감사 로그가 남는다(금액·계약·권한·개인정보).
- API 문서(OpenAPI)가 갱신되었다. 헬프센터 가이드 초안이 있다.
- PR 에 기능 ID·스크린샷·테스트 결과가 있고 리뷰 승인을 받았다.

18.2 릴리스 단위

- 범위표의 기능이 모두 18.1 을 만족한다.
- E2E 핵심 시나리오·성능·접근성·보안 게이트를 통과했다.
- 마이그레이션이 스테이징에서 검증되었고 롤백 계획이 있다.
- 릴리스 노트·상태 페이지·헬프센터가 갱신되었다.
- 검수표에 발주자 서명이 있다.

부록 템플릿과 목록

A. 환경 변수·시크릿 목록 (API)

이름	종류	용도
APP_ENV	변수	local / staging / production
APP_BASE_URL, OWNER_BASE_URL, TENANT_BASE_URL	변수	링크 생성
HYPERDRIVE	바인딩	Postgres 연결
DATABASE_URL (local 만)	시크릿	로컬 Postgres
AUTH_SECRET	시크릿	Better Auth 서명 키
PII_ENC_KEY_V1	시크릿	개인정보 필드 암호화 키(버전)
KV, R2_MEDIA, QUEUE_NOTIFY, QUEUE_PDF, QUEUE_IMPORT, QUEUE_WEBHOOK, WF_FEE_RUN, WF_BILLING, WF_REPORT, BROWSER, RL_LOGIN	바인딩	Cloudflare 리소스
SUPABASE_STORAGE_URL, SUPABASE_SERVICE_KEY	시크릿	문서 스토리지(서버 측만)
ALIMTALK_PROVIDER, ALIMTALK_API_KEY, ALIMTALK_SENDER_KEY	시크릿	알림톡
SMS_API_KEY, EMAIL_API_KEY	시크릿	SMS·이메일
PG_PROVIDER, PG_SECRET_KEY, PG_WEBHOOK_SECRET	시크릿	결제
TAXINVOICE_PROVIDER, TAXINVOICE_API_KEY	시크릿	세금계산서
ESIGN_API_KEY, OCR_API_KEY	시크릿	전자계약·OCR
GOV_BIZNO_KEY, GOV_BUILDING_KEY, ADDRESS_API_KEY, KAKAO_MAP_KEY	시크릿	공공·지도 API
SENTRY_DSN, TURNSTILE_SECRET	시크릿	모니터링·봇 차단

B. wrangler 설정 예시 (API, 발췌)

```
name = "asseton-api"
main = "src/index.ts"
compatibility_date = "2026-10-01"
compatibility_flags = ["nodejs_compat"]

[[hyperdrive]]
```

```
binding = "HYPERDRIVE"
id = "<hyperdrive-id>"

[[kv_namespaces]]
binding = "KV"
id = "<kv-id>"

[[r2_buckets]]
binding = "R2_MEDIA"
bucket_name = "asseton-media"

[[queues.producers]]
binding = "QUEUE_NOTIFY"
queue = "asseton-notify"

[[queues.consumers]]
queue = "asseton-notify"
max_batch_size = 20
max_retries = 5
dead_letter_queue = "asseton-notify-dlq"

[[workflows]]
binding = "WF_FEE_RUN"
name = "fee-run"
class_name = "FeeRunWorkflow"

[triggers]
crons = ["0 21 * * *", "10 15 * * *", "0 15 1 * *"]   # KST 06:00 / 00:10 / 매월 1일 00:00

[browser]
binding = "BROWSER"

[env.staging]
name = "asseton-api-staging"
# 바인딩 ID는 환경별로 별도
```

C. PR 템플릿

```
## 기능 ID
FM-04

## 무엇을 바꿨나
- 건물 조건 → 의무 항목 생성 규칙 엔진 (packages/rules/legal)

## 어떻게 확인했나
- [ ] 단위 테스트 (조건식 24종)
- [ ] 통합 테스트 (POST /v1/fm/legal-inspections/generate)
- [ ] 스크린샷 (PC / 모바일)
- [ ] 교차 접근 테스트 포함

## 영향
- 마이그레이션: 있음 / 없음
- 규칙 설정 변경: 있음 / 없음
- 문서 갱신: OpenAPI / 헬프센터
```

D. 이슈 템플릿 (결함)

```
제목: [S2][PM-04] 공실 호실 공용 항목이 임차사에 배분됨
환경: staging / 브라우저 / 계정 역할
재현 절차: 1. … 2. … 3. …
기대 결과 / 실제 결과
첨부: 스크린샷, req_id, 관련 데이터 ID
등급 근거: 금액 오류(S1) / 핵심 시나리오 불가(S2) / 우회 가능(S3) / 편의(S4)
```

E. ADR 템플릿

```
# ADR-0007: 기록 데이터베이스를 서울 리전 PostgreSQL로 둔다
상태: 승인 (2026-11-xx)
맥락: Cloudflare 저장소는 한국 내 저장을 보장하지 않음. 개인정보·계약·금액 데이터의 위치 요구.
결정: Supabase PostgreSQL(ap-northeast-2) + Hyperdrive. 캐시·파일 일부만 Cloudflare.
대안: D1 테넌트별 DB(비용 최소, 위치 보장 불가) / 자체 VM Postgres(운영 부담)
결과: 트랜잭션·RLS 확보, 월 비용 증가(Supabase Pro), 국외 처리 공개 문구 필요
```

F. 출시 전 보안 체크리스트 (요약)

- 인증: 2FA 강제 역할 적용, 잠금·회전·로그아웃 확인 / 권한: 라우트 선언 100%, 교차 접근 테스트 0 건
- 데이터: 개인정보 필드 암호화, 백업 암호화, PITR 활성, 복구 리허설 완료
- 전송·헤더: HSTS, CSP, SameSite, 서명 URL 만료
- 입력: Zod 전 라우트, 파일 검증·재인코딩, 레이트리밋·Turnstile
- 비밀: 저장소 비밀 탐지 통과, 시크릿 최소 권한, 회전 절차 문서
- 로그: PII 없음 확인(샘플 검사), 감사 로그 불변
- 의존성: critical 0, SBOM 제출
- 외부: 모의해킹 지적 사항 조치 완료 보고서
- 법무: 약관·처리방침·처리위탁·국외 처리 공개 게시, 유출 대응 절차 훈련 1 회